

1 Information about this chapter

SMTP or Simple Mail Transfer Protocol is used for sending emails over an IP network. The protocol can be used between a client and a server or between two servers, usually combined with IMAP and POP3 protocols. In most cases it is used as a client-server protocol. When sending an email, the SMTP client is also known as Mail User Agent (MUA) takes the e-mail and converts it into a header and a body and uploads both to the SMTP server. The SMTP server also has a software basis called Mail Transfer Agent (MTA) which performs the operation of sending and receiving emails. MTA also checks for email size and probable spam and then stores it and it uses commands like `VRFY` and `RCPT` to check for user existence, if not configured correctly, those can be exploited to enumerate users. Usually, MTA is preceded by Mail Submission Agent (MSA) which checks the validity and origin of the mail. MSA is also called Relay server. MTA performs the search of the IP address of the recipient mail server through the DNS protocol. After arriving on the destination SMTP server, data packets are reassembled and from there the Mail Delivery Agent (MDA) transfers it to the recipient's mailbox. SMTP is only for sending and forwarding emails.

2 Ports used

By default, SMTP servers accept connection requests on port 25, newer versions of SMTP accept connection requests over port 587 TCP. Port 587 is used to receive mail from authenticated users/servers. Using the `STARTTLS` command over this port enables encrypted communications.

3 Features

In order to prevent auth spam, SMTP servers use the extended protocol ESMTP with SMTP-Auth, which prevents a person to bruteforce the authentication mechanism that allow only authorized users to send e-mails.

4 Disadvantages/Flaws/Vulnerabilities

A major disadvantage is that when sending an email over SMTP protocol, you don't get a confirmation that the email has been received. Second, when establishing a connection over an open SMTP relay, users are not authenticated which often leads to this being used as a spam attack. For this reason ESMTP exists, ESMTP uses TLS. A dangerous setting to enable when configuring an SMTP server is the `mynetworks` option, if enabled like this: `mynetworks = 0.0.0.0/0`, called open relay configuration, can lead to users sending fake emails and initialize communications between multiple parties. Another attack would be to spoof the email and read it. In order to prevent spoofing, persons who configure the server can enable SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail) and DMARC, mechanisms that verify the authenticity of the sender at DNS level.

5 Usage

In order to interact with an SMTP server we can use the telnet command, which has the following syntax:

Footprinting: SMTP

```
telnet <IP> <PORT>
```

This establishes a TCP connection.

Interactive work

1. Enumerate the SMTP service and submit the banner, including its version as the answer.

In order to do this, we will use the `nmap` command as follows:

```
sudo nmap <IP> -sC -sV -p25
```

We are interested only in finding information about port 25, the `-sV` flag helps us find out the services and their versions that are running on the SMTP server and the `-sC` flag is for extracting extra information if available.

```
~ % sudo nmap -sC -sV -p25
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 16:59 +0300
Stats: 0:00:35 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.99% done; ETC: 16:59 (0:00:00 remaining)
Stats: 0:00:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 50.00% done; ETC: 17:00 (0:00:15 remaining)
Stats: 0:01:12 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 87.50% done; ETC: 17:00 (0:00:04 remaining)
Nmap scan report for 
Host is up (0.19s latency).

PORT      STATE SERVICE VERSION
25/tcp    open  smtp    220 InFreight ESMTP v2.11
|_ Syntax: EHLO hostname
|_ smtp-commands: mail1, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF:ello,36,"220\x20InFreight\x20ESMTP\x20v2.11\r\n501\x20Syntax:\x20EHLO\x20hostname\r\n";
```

2. Enumerate the SMTP service even further and find the username that exists on the system. Submit it as the answer.

In order to find out the username that exists on the system, we will use the wordlist provided by HTB in the resource section and we will open a new terminal to run metasploit through the `msfconsole` command. Forward, we will search for `smtp_enum`. `smtp_enum` works this way: it sends commands to the SMTP server like `VRFY <username>` or `RCPT TO: <username>` in order to verify the existence of a user. If the server responds with code `250` or `252` (depends on which command is sent), the user exists, if the response is `550`, the user does not exist. Metasploit helps us automate this process.

Footprinting: SMTP

```
msf6 > search smtp_enum

Matching Modules
=====

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/smtp/smtp_enum         .               normal No     SMTP User Enumeration Utility
```

We will select the highlighted module with the command `use 0` and then we will execute `options` in order to see what we need to configure before running the enumeration.

```
msf6 auxiliary(scanner/smtp/smtp_enum) > options

Module options (auxiliary/scanner/smtp/smtp_enum):

Name      Current Setting  Required  Description
-----
RHOSTS    25               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     25               yes       The target port (TCP)
THREADS    1               yes       The number of concurrent threads (max one per host)
UNIXONLY   true            yes       Skip Microsoft bannered servers when testing unix users
USER_FILE  /opt/metasploit-framework/embedded/framework/data/wordlists/unix_users.txt  yes       The file that contains a list of probable users accounts.
```

We need to set `RHOSTS` and `USER_FILE`, the `RPORT` is already set to 25, set `RHOSTS <IP>` and set `USER_FILE path/to/file`. After setting up everything, execute the `exploit` command for the enumeration to start. After some time, we will see that we get our flag:

```
msf6 auxiliary(scanner/smtp/smtp_enum) > exploit
[*] :25 - :25 Banner: 220 InFreight ESMTP v2.11
[+] :25 - :25 Users found: robin
[*] :25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```